

1. 네트워크 기술 취약점

1.1. RIP 취약점

위험도 : 상 (High)

설명 :

- RIPv1은 인증 기능이 전혀 없어 모든 라우팅 업데이트 패킷을 신뢰하며, RIPv2는 평문 인증 사용 시 패킷 캡처를 통해 비밀번호가 노출됨
- UDP 520번 포트를 사용하여 출발지 IP 위조가 용이한 비연결형 프로토콜임

영향 :

- 공격자가 허위 라우팅 정보를 주입하여 트래픽을 가로채는 중간자 공격(MitM)이나 블랙홀(Blackhole) 경로를 생성하여 대규모 네트워크 장애를 유발함

1.2. EIGRP

위험도 : 상 (High)

설명 :

- 기본 설정에서 인증이 없으며, 동일한 AS(Autonomous System) 번호를 사용하는 인접 장비를 무조건적으로 신뢰함
- 공격자가 Hello 패킷을 전송하여 인접 관계(Neighbor)를 맺는 것만으로 내부 토폴로지 정보 탈취 가능

영향 :

- 잘못된 경로 정보 주입으로 인한 데이터 유출 및 SIA(Stuck-In-Active) 상태 유도를 통한 라우터 자원 고갈(DoS) 공격 발생

1.3. Prefix-list

위험도 : 중 (Medium)

설명 :

- 라우팅 경로를 필터링하는 Prefix-list는 상위 순번(Sequence Number)에 넓은 대역의 허용(permit) 규칙이 위치할 경우, 하위의 세부 차단 규칙이 무시되는 논리적 구조를 가짐
- le(less than), ge(greater than) 옵션 설정 오류 시 관리자가 의도한 특정 서브넷 범위를 벗어나는 경로까지 수용하게 됨

영향 :

- Route Leaking(경로 유출): 내부 사설 IP 대역 정보가 외부 ISP로 유출되거나, 외부의 잘못된 경로 정보를 수신하여 데이터가 엉뚱한 곳으로 전송(Blackhole 또는 Hijacking)됨
- 보안 정책상 차단되어야 할 대역이 라우팅 테이블에 등록되어 내부망 침투의 경로를 제공함

1.4. port-security

위험도 : 중 (Medium)

설명 :

- 물리 포트에 접속 가능한 MAC 주소를 제한하지만, MAC 주소는 소프트웨어적으로 쉽게 변조(Spoofing)가 가능함

영향 :

- 정상 단말의 MAC 주소를 스니핑한 공격자가 자신의 MAC을 위조하여 포트 보안을 우회하고 내부 네트워크에 무단 접속함

1.5. FHRP

위험도 : 상 (High)

설명 :

- 가상 IP(VIP)를 공유하는 과정에서 우선순위(Priority)를 기반으로 Master/Active 장비를 선출하는데, 인증 부재 시 공격자가 더 높은 우선순위 패킷을 송신할 수 있음

영향 :

- 공격자가 가상 게이트웨이 권한을 탈취하여 모든 하위 단말의 외부 트래픽을 가로채고 조작하는 중간자 공격(MitM) 수행 가능

1.6. ACL

위험도 : 상 (High)

설명 :

- 패킷의 상태를 추적하지 않고 단순 헤더 정보(IP, Port)만 검사하므로, TCP Flag(ACK 등)를 조작한 패킷을 정상적인 응답 패킷으로 오인함

영향 :

- IP 스푸핑이나 패킷 단편화(Fragmentation) 기법을 사용한 공격 패킷이 필터링 정책을 우회하여 내부 주요 서버에 도달함

1.7. SPAN(RSPAN)

위험도 : 상 (High)

설명 :

- 미러링된 트래픽을 특정 VLAN(RSPAN VLAN)을 통해 원격으로 전송하는데, 해당 VLAN이 트렁크(Trunk) 포트를 통해 불필요한 구간까지 확산됨

영향 :

- 공격자가 RSPAN VLAN에 접근할 수 있는 스위치 포트에 연결할 경우, 네트워크 전체의 미러링 트래픽을 스니핑하여 민감 정보 탈취 가능

2. 라우팅 및 인프라 보안 강화

2.1. [단기] 라우팅 프로토콜(RIP, EIGRP) 인증 강화

- 기본 설정의 인증 부재를 해결하기 위해 MD5 또는 SHA-256 알고리즘 기반의 Key-chain 인증을 적용해야 함
- 인증되지 않은 장비의 허위 라우팅 정보 주입을 차단하여 경로 조작을 통한 중간자 공격(MitM)을 원천 방지함
예) RIPv2 MD5 인증 적용, EIGRP 인증 키(Key-chain) 설정

2.2. [단기] Prefix-list를 통한 경로 필터링 최적화

- 라우팅 경로 유입/유출 시 순차적인 Prefix-list를 적용하여 사설 IP 대역이나 비인가 대역의 정보를 차단해야 함

2.3. [단기] Port-Security 및 Sticky MAC 활성화

- 스위치 포트별로 접속 가능한 MAC 주소 개수를 제한하고, 학습된 주소를 고정하는 Sticky 옵션을 활성화해야 함
- 비인가 장비 연결 시 해당 포트를 즉시 차단(shutdown)하여 MAC 스누핑을 통한 내부망 무단 접근을 방어함
예) 포트당 허용 MAC 1개 설정 및 위반 시 에러 상태(err-disable) 전환

2.4. [단기] FHRP(게이트웨이 이중화) 권한 탈취 방지

- HSRP, VRRP 등 게이트웨이 가용성 프로토콜에 MD5 인증을 적용하고 우선순위를 엄격히 관리해야 함
- 동일 브로드캐스트 도메인 내 공격자가 가짜 게이트웨이(Active/Master) 권한을 가로채는 것을 방지함
예) HSRP 인증 문자열 적용 및 부적절한 Preempt 방지 설정

2.5. [단기] ACL(액세스 제어 리스트) 정책 고도화

- 단순 IP/Port 기반 차단을 넘어 established 옵션이나 상태 기반 필터링을 활용해야 함
- 내부에서 시작된 연결에 대한 응답 패킷만 허용함으로써, 외부에서 유입되는 비정상적인 스캐닝 및 스누핑 패킷을 차단함

2.6. [단기] SPAN 및 RSPAN 트래픽 관리 강화

- 모니터링 전용 VLAN(RSPAN VLAN)이 필요한 트렁크 포트로부터 전송되도록 VLAN Pruning을 설정하고 접근을 제한해야 함
- 미러링 트래픽의 무분별한 확산을 막아 인가되지 않은 장비가 전체 네트워크 통신 내용을 스니핑하는 것을 방지함
예) 모니터링 세션 종료 후 no monitor session 명령어로 실시간 미러링 비활성화